

Penetration Test Report — Q4 2024

Grey-box assessment of the Nexaform Analytics Platform, its public API surface, and supporting cloud infrastructure.

Client	Nexaform Technologies, Inc.
Assessor	Ironwood Security — Offensive Services
Engagement Window	October 21 – November 1, 2024
Methodology	OWASP WSTG 4.2, OWASP API Top 10 (2023), PTES
Scope	app.nexaform.io, api.nexaform.io, AWS production VPC (grey-box)
Retest Date	November 22, 2024 — all findings verified remediated
Overall Risk	LOW (post-remediation)

Executive Summary

Ironwood Security performed a grey-box penetration test of the Nexaform Analytics Platform between October 21 and November 1, 2024. The assessment covered the public web application, the authenticated REST API, tenant isolation boundaries, and externally reachable cloud infrastructure. Testing identified **7 findings**: 0 critical, 1 high, 2 medium, 3 low, and 1 informational. No finding permitted cross-tenant data access or unauthenticated access to customer data. All findings were remediated by Nexaform and confirmed closed on retest (November 22, 2024).



Findings Overview

ID	Severity	Finding	Category	Status
----	----------	---------	----------	--------

IW-01	HIGH	Rate limiting absent on password-reset endpoint enabled account-enumeration & brute force	API4:2023	Resolved
IW-02	MED	Stored XSS via unsanitised dashboard widget title	WSTG-CLNT-01	Resolved
IW-03	MED	IDOR on report-export job status (predictable job IDs)	API1:2023	Resolved
IW-04	LOW	Missing Strict-Transport-Security max-age on api subdomain	WSTG-CONF-07	Resolved
IW-05	LOW	Verbose error message discloses framework version	WSTG-ERRH-01	Resolved
IW-06	LOW	Session cookie missing SameSite attribute	WSTG-SESS-02	Resolved
IW-07	INFO	S3 bucket allows unencrypted-transport policy (no measurable exposure)	Cloud	Resolved

Selected Finding Detail — IW-01 (High)

Description

The `POST /api/v1/auth/password-reset` endpoint did not enforce rate limiting. An attacker could submit unlimited requests, distinguishing valid from invalid accounts by response timing and enabling credential brute-forcing of accounts without SSO enforced.

Business Impact

Account takeover of local (non-SSO) accounts; user enumeration aiding targeted phishing. Rated High due to direct path to unauthorized account access.

Remediation (Verified Closed)

- Per-IP and per-account token-bucket rate limiting added (10 req/min) with exponential backoff.
- Password-reset responses made uniform to prevent enumeration.
- Alerting added to the SIEM for reset-request bursts.

Retested 2024-11-22 — rate limiting confirmed active (HTTP 429 after threshold); enumeration no longer possible. Finding closed.

Methodology & Attestation

Testing followed the OWASP Web Security Testing Guide v4.2, the OWASP API Security Top 10 (2023), and the Penetration Testing Execution Standard. Both automated tooling (authenticated Burp Suite Pro

scans, nuclei) and manual exploitation were used. This report attests that, as of the November 22, 2024 retest, all identified findings were remediated and no critical- or high-risk issues remain in the tested scope.

Prepared by Ironwood Security. Distribution limited to Nexaform Technologies and its auditors under NDA.